

OnRe Solana Diff

Executive Summary

This audit report was prepared by Quantstamp, the leader in blockchain security.

Type	RWA	Documentation quality	Medium
Timeline	2025-08-25 through 2025-08-26	Test quality	Medium
Language	Rust	Total Findings	1 Fixed: 1
Methods	Architecture Review, Unit Testing, Functional Testing, Computer-Aided Verification, Manual Review	High severity findings ⓘ	0
Specification	None	Medium severity findings ⓘ	0
Source Code	onre-finance/onre-sol  #ce75db1 	Low severity findings ⓘ	0
Auditors	- Darren Jensen Auditing Engineer - Hamed Mohammadi Auditing Engineer - Paul Clemson Auditing Engineer	Undetermined severity ⓘ	0

ty findin gs	
Infor matio nal findin gs	1 Fixed: 1

Summary of Findings

The Onre protocol is a Solana program built with the Anchor framework which facilitates the sale of real world assets via an offers system. The protocol allows an authorized user to create offers specifying the buy and sell tokens, a sale price and a maximum amount of tokens available to purchase. The user can then choose to fill these orders (completely or partially) by paying the quoted price.

This audit is a diff audit focusing on the following:

- The addition of an intermediary account which handles moving buy and sell tokens between the user and the protocol.
- `initialize.rs` adds some extra code to handle initializing the permissionless account.
- `take_offer_one_permissionless.rs` is new, but largely duplicate code from the `take_offer_one()` function logic.
- All remaining code is unchanged.

Overall, the code changes are well engineered and adheres to good security practices. The audit review found some missing input validation, missing documentation and duplicate code which we recommend to be addressed.

The updates indicate that finding `ONRE-1` as well as Suggestions S1 and S2 have all been successfully fixed, addressing the previously identified vulnerabilities. However, Suggestion S3 has been acknowledged, with the client recognizing the issue of code duplication but opting to defer resolution until a new version of the program is released.

ID	DESCRIPTION	SEVERITY	STATUS
ONRE-1	Unboxed Accounts May Trigger Stack Overflows Causing Instruction Failure	Informational ⓘ	Fixed

Assessment Breakdown

Quantstamp's objective was to evaluate the repository for security-related issues, code quality, and adherence to specification and best practices.

Disclaimer

Only features that are contained within the repositories at the commit hashes specified on the front page of the report are within the scope of the audit and fix review. All features added in future revisions of the code are excluded from consideration in this report.

Possible issues we looked for included (but are not limited to):

- Transaction-ordering dependence
- Timestamp dependence
- Mishandled exceptions and call stack limits
- Unsafe external calls
- Integer overflow / underflow
- Number rounding errors
- Reentrancy and cross-function vulnerabilities
- Denial of service / logical oversights
- Access control
- Centralization of power
- Business logic contradicting the specification
- Code clones, functionality duplication
- Gas usage
- Arbitrary token minting

Methodology

1. Code review that includes the following
 1. Review of the specifications, sources, and instructions provided to Quantstamp to make sure we understand the size, scope, and functionality of the smart contract.
 2. Manual review of code, which is the process of reading source code line-by-line in an attempt to identify potential vulnerabilities.
 3. Comparison to specification, which is the process of checking whether the code does what the specifications, sources, and instructions provided to Quantstamp describe.
2. Testing and automated analysis that includes the following:
 1. Test coverage analysis, which is the process of determining whether the test cases are actually covering the code and how much code is exercised when we run those test cases.
 2. Symbolic execution, which is analyzing a program to determine what inputs cause each part of a program to execute.
3. Best practices review, which is a review of the smart contracts to improve efficiency, effectiveness, clarity, maintainability, security, and control based on the established industry and academic practices, recommendations, and research.
4. Specific, itemized, and actionable recommendations to help you take steps to secure your smart contracts.

Operational Considerations

- Any tokens sent directly to the intermediary address will likely be stuck.
- The `PermissionlessAccount` used within the protocol is expected to have been created prior to users calling `take_offer_one_permissionless()`.
- The boss role in the protocol is trusted to ensure the correct tokens are offered at the correct prices.
- The boss is also trusted to open redemption windows for users to liquidate their tokenized assets and to allow ample time for offers to be filled.
- The Associated Token Accounts (ATAs) used within the protocol are expected to have been created prior to interacting with the program.

Key Actors And Their Capabilities

The protocol has one authorized role:

Boss: The program's administrator. This role has the power to create offers and close offers. The role also has the authority to set a new `boss`. The `boss` account is also responsible for calling `initialize_permissionless_account()`.

Findings

ONRE-1

Unboxed Accounts May Trigger Stack Overflows Causing Instruction Failure

• Informational ⓘ Fixed

✓ Update

Marked as "Fixed" by the client.

Addressed in: `df5b47aca0adc8f8f8f139b891547f20f70a7095`.

i Update

The fix introduces the use of `anchor_spl::token_interface::TokenAccount`, enabling compatibility with both the legacy SPL Token program and the Solana Token-2022 program.

File(s) affected:

`programs/onreapp/src/instructions/take_offer_one_permissionless.rs`

Description: In multiple places, accounts are held directly on the stack (e.g., `Account<'info, T>`). However, large or numerous account structs combined with deeper call stacks can exceed

per-frame limits and cause runtime access violations, leading to transaction reverts. Practically, this manifests as stack overflow errors, producing instruction failures and degraded UX/temporary denial of service for affected flows. This directly affects reliability and user experience.

Recommendation: Consider applying heap allocation for larger account types and interfaces, for example:

- Replace stack-allocated accounts with `Box<Account<'info, T>>` where appropriate.
- Use `InterfaceAccount<'info, TokenAccount>` (via `token_interface`) for SPL token accounts.
- Use `AccountInfo<'info>` for PDAs that don't require Anchor deserialization.

Moreover, it is recommended to ensure that the Solana CLI is up to date, as ongoing improvements to the compiler and testing framework may impact results. For example, running tests with Solana CLI v2.3.9 resulted in 8 failing tests related to this finding.

Auditor Suggestions

S1 Missing Input Validation

Fixed

✓ Update

Marked as "Fixed" by the client.

Addressed in: `6e3cf976a1edcc0ca3340a70423b3a5d4e363321` .

File(s) affected: `programs/onreapp/src/instructions/initialize.rs`

Description: The `inititalize_permissionless_account()` function in `initialize.rs` does not validate that the `name` passed to the function is not an empty string. The `name` value of the `permissionless_account` is immutable after initialization meaning a mistake here may require a redeployment. Moreover, the `inititalize_permissionless_account()` function does not emit an event after successfully creating a new `PermissionlessAccount` , reducing observability.

Recommendation: Consider validating the `name` argument passed to the `inititalize_permissionless_account()` function is not an empty string and does not only contain spaces. Moreover, consider emitting an event after creating the `PermissionlessAccount` .

S2 Missing Documentation

Fixed

✓ Update

Marked as "Fixed" by the client.

Addressed in: d6a7adaf6dfd1abdcbdac7528acab06c6164dea2 .

File(s) affected: `programs/onreapp/src/lib.rs`

Description: The `initialize_permissionless_account()` function in `lib.rs` is missing documentation. Inline documentation improves the overall readability of the codebase and should be fleshed out where possible.

Recommendation: Consider adding inline documentation for the `initialize_permissionless_account()` function.

S3

Consider Moving Identical Functions to a Shared Utils Module to Improve Maintainability

Acknowledged

Update

Marked as "Acknowledged" by the client.

The client provided the following explanation:

We are aware of the duplication. However, we are working on a new version of the program with a lot of new features and changes, so we are willing to accept this duplication until then. The code duplication will be addressed in the new version of the program.

File(s) affected:

`programs/onreapp/src/instructions/take_offer_one_permissionless.rs`

Description: The two functions `calculate_current_sell_amount()` and `calculate_buy_amount()` have identical implementations across both modules `take_offer_one_permissionless` and `take_offer`. This can result in issues for future maintenance if potential changes in one version are not reflected in the other.

Recommendation: Consider introducing a shared component in the codebase and moving the implementation of these two functions to the shared component, then importing it in the above modules.

Definitions

- **High severity** – High-severity issues usually put a large number of users' sensitive information at risk, or are reasonably likely to lead to catastrophic impact for client's reputation or serious financial implications for client and users.
- **Medium severity** – Medium-severity issues tend to put a subset of users' sensitive information at risk, would be detrimental for the client's reputation if exploited, or are reasonably likely to lead to moderate financial impact.
- **Low severity** – The risk is relatively small and could not be exploited on a recurring basis, or is a risk that the client has indicated is low impact in view of the client's business circumstances.
- **Informational** – The issue does not pose an immediate risk, but is relevant to security best practices or Defence in Depth.
- **Undetermined** – The impact of the issue is uncertain.
- **Fixed** – Adjusted program implementation, requirements or constraints to eliminate the risk.
- **Mitigated** – Implemented actions to minimize the impact or likelihood of the risk.
- **Acknowledged** – The issue remains in the code but is a result of an intentional business or design decision. As such, it is supposed to be addressed outside the programmatic means, such as: 1) comments, documentation, README, FAQ; 2) business processes; 3) analyses showing that the issue shall have no negative consequences in practice (e.g., gas analysis, deployment settings).

Test Suite Results

With the following dependencies installed:

- solana-cli 2.2.6 (src:e5cdee7c; feat:4066693973, client:Agave)
- anchor-cli 0.31.1
- rustc 1.89.0 (29483883e 2025-08-04)
- NodeJS v20.19.4

The test suit can be run by running the `anchor test` command.

```
PASS  tests/take_offer.spec.ts
PASS  tests/make_offer.spec.ts
PASS  tests/close_offer.spec.ts
PASS  tests/onreapp.spec.ts (50.699 s)
```

```
Test Suites: 4 passed, 4 total
Tests:      59 passed, 59 total
Snapshots:  0 total
Time:       54.533 s
```

Code Coverage

The protocol's test suite covers the majority of happy cases as well as some edge cases.

Changelog

- 2025-08-27 - Initial report
- 2025-09-17 - Final report

About Quantstamp

Quantstamp is a global leader in blockchain security. Founded in 2017, Quantstamp's mission is to securely onboard the next billion users to Web3 through its best-in-class Web3 security products and services.

Quantstamp's team consists of cybersecurity experts hailing from globally recognized organizations including Microsoft, AWS, BMW, Meta, and the Ethereum Foundation. Quantstamp engineers hold PhDs or advanced computer science degrees, with decades of combined experience in formal verification, static analysis, blockchain audits, penetration testing, and original leading-edge research.

To date, Quantstamp has performed more than 500 audits and secured over \$200 billion in digital asset risk from hackers. Quantstamp has worked with a diverse range of customers, including startups, category leaders and financial institutions. Brands that Quantstamp has worked with include Ethereum 2.0, Binance, Visa, PayPal, Polygon, Avalanche, Curve, Solana, Compound, Lido, MakerDAO, Arbitrum, OpenSea and the World Economic Forum.

Quantstamp's collaborations and partnerships showcase our commitment to world-class research, development and security. We're honored to work with some of the top names in the industry and proud to secure the future of web3.

Notable Collaborations & Customers:

- Blockchains: Ethereum 2.0, Near, Flow, Avalanche, Solana, Cardano, Binance Smart Chain, Hedera Hashgraph, Tezos
- DeFi: Curve, Compound, Maker, Lido, Polygon, Arbitrum, SushiSwap
- NFT: OpenSea, Parallel, Dapper Labs, Decentraland, Sandbox, Axie Infinity, Illuvium, NBA Top Shot, Zora
- Academic institutions: National University of Singapore, MIT

Timeliness of content

The content contained in the report is current as of the date appearing on the report and is subject to change without notice, unless indicated otherwise by Quantstamp; however, Quantstamp does not guarantee or warrant the accuracy, timeliness, or completeness of any report you access using

the internet or other means, and assumes no obligation to update any information following publication or other making available of the report to you by Quantstamp.

Notice of confidentiality

This report, including the content, data, and underlying methodologies, are subject to the confidentiality and feedback provisions in your agreement with Quantstamp. These materials are not to be disclosed, extracted, copied, or distributed except to the extent expressly authorized by Quantstamp.

Links to other websites

You may, through hypertext or other computer links, gain access to web sites operated by persons other than Quantstamp. Such hyperlinks are provided for your reference and convenience only, and are the exclusive responsibility of such web sites' owners. You agree that Quantstamp are not responsible for the content or operation of such web sites, and that Quantstamp shall have no liability to you or any other person or entity for the use of third-party web sites. Except as described below, a hyperlink from this web site to another web site does not imply or mean that Quantstamp endorses the content on that web site or the operator or operations of that site. You are solely responsible for determining the extent to which you may use any content at any other web sites to which you link from the report. Quantstamp assumes no responsibility for the use of third-party software on any website and shall have no liability whatsoever to any person or entity for the accuracy or completeness of any output generated by such software.

Disclaimer

The review and this report are provided on an as-is, where-is, and as-available basis. To the fullest extent permitted by law, Quantstamp disclaims all warranties, expressed implied, in connection with this report, its content, and the related services and products and your use thereof, including, without limitation, the implied warranties of merchantability, fitness for a particular purpose, and non-infringement. You agree that access and/or use of the report and other results of the review, including but not limited to any associated services, products, protocols, platforms, content, and materials, will be at your sole risk. FOR AVOIDANCE OF DOUBT, THE REPORT, ITS CONTENT, ACCESS, AND/OR USAGE THEREOF, INCLUDING ANY ASSOCIATED SERVICES OR MATERIALS, SHALL NOT BE CONSIDERED OR RELIED UPON AS ANY FORM OF FINANCIAL, INVESTMENT, TAX, LEGAL, REGULATORY, OR OTHER ADVICE. This report is based on the scope of materials and documentation provided for a limited review at the time provided. You acknowledge that Blockchain technology remains under development and is subject to unknown risks and flaws and, as such, the report may not be complete or inclusive of all vulnerabilities. The review is limited to the materials identified in the report and does not extend to the compiler layer, or any other areas beyond the programming language, or programming aspects that could present security risks. The report does not indicate the endorsement by Quantstamp of any particular project or team, nor guarantee its security, and may not be represented as such. No third party is entitled to rely on the report in any way, including for the purpose of making any decisions to buy or sell a product, service or any other asset. Quantstamp does not warrant, endorse, guarantee, or assume responsibility for any product or service advertised or offered by a third party, or any open source or third-party software, code, libraries, materials, or information to, called by, referenced by or accessible through the report, its content, or any related services and products, any hyperlinked websites, or any other websites or mobile applications, and we will not be a party to or in any way

be responsible for monitoring any transaction between you and any third party. As with the purchase or use of a product or service through any medium or in any environment, you should use your best judgment and exercise caution where appropriate.

